ALLEGATO 01 – OBBLIGHI DI CYBERSECURITY, SUPPLY CHAIN E NOTIFICA DEGLI INCIDENTI

Allegato al Bando / Contratto di fornitura n. xxx del xx/xx/xxxx tra A.S.L. V.C.O. (di seguito indicato come "Committente") e XXXXXXXXX (di seguito indicato come "Fornitore").

PREMESSA

Il Committente opera quali soggetto pubblico e destinatario degli obblighi di cybersecurity ex Direttiva (UE) 2022/2555 (NIS2) e D.Lgs. 138/2024. Pertanto, ai sensi dell'art. 21, par. 2, lett. d) NIS2 e dell'art. 24, co. 2, lett. d) D.Lgs. 138/2024, è obbligatorio integrare misure di gestione del rischio ICT in tutte le fasi della catena di fornitura, incluse la valutazione delle vulnerabilità specifiche del Fornitore diretto, la qualità delle pratiche di cybersecurity e lo sviluppo sicuro dei prodotti e dei servizi oggetto del presente contratto.

Le parti convengono che il presente Allegato costituisce parte integrante e sostanziale del Contratto di Fornitura e che il suo mancato rispetto equivale a inadempimento contrattuale ai fini dell'art. 1453 e seguenti del Codice Civile, fermo restando l'applicazione delle sanzioni amministrative pecuniarie di cui all'art. 35 D.Lgs. 138/2024.

RIFERIMENTI NORMATIVI

Ai fini del presente Allegato si fa riferimento a:

- Direttiva (UE) 2022/2555 (NIS2);
- D.Lgs. 13 novembre 2024, n. 138 (Decreto di recepimento NIS2);
- Regolamento (UE) 2016/679 (GDPR) e D.Lgs. 196/2003;
- UNI CEI EN ISO/IEC 27001:2022 e UNI CEI EN ISO/IEC 27002:2022;
- Linee guida e raccomandazioni ENISA e ACN vigenti.

DEFINIZIONI

Per le finalità del presente Allegato valgono le definizioni di cui agli artt. 3 NIS2 e 3 D.Lgs. 138/2024; in particolare:

- **"Incidente ICT"**: un evento che compromette la sicurezza delle reti e dei sistemi informativi, con impatto sulla riservatezza, integrità o disponibilità dei dati o dei servizi del Committente;
- **"Subfornitore"**: qualsiasi terzo a monte o a valle del Fornitore che eroga componenti, servizi ICT o logistici rilevanti per l'esecuzione del Contratto;
- **"Audit"**: attività di verifica ispettiva, documentale o tecnica (inclusi vulnerability assessment e penetration test) condotta dal Committente o da soggetti terzi da esso incaricati.

AMBITO DI APPLICAZIONE

Il presente Allegato si applica a tutti i beni, servizi, attività di sviluppo, manutenzione, cloud, hosting, supporto e consulenza oggetto del Contratto, qualora il Fornitore o i suoi Subfornitori:

a) accedano, elaborino, trasmettano o conservino dati, anche personali, del Committente;

b) gestiscano sistemi, reti, infrastrutture critiche o componenti tecnologiche connesse ai servizi erogati al Committente.

1 OBBLIGHI DEL FORNITORE

Come prefiltro obbligatorio, il Fornitore deve compilare e sottoscrivere la **Checklist di Conformità ICT & Cybersecurity**, Allegato D al contratto.

Le dichiarazioni rese in tale modulo hanno valore di dichiarazione sostitutiva di certificazione ai sensi del D.P.R. 445/2000 e costituiscono parte integrante dell'offerta.

Il Fornitore si obbliga a:

a) mantenere un Sistema di Gestione per la Sicurezza delle Informazioni (SGSI) conforme alla UNI CEI EN ISO/IEC 27001:2022, ove applicabile, garantendo il rispetto delle Clausole 4-10 e dei controlli A.5.19, A.5.20, A.5.21, A.5.22, A.5.23;

b) implementare misure tecniche e organizzative adeguate al rischio, basate sullo *state-of-the-art*, coerentemente con l'art. 21 NIS2 e l'art. 20 D.Lgs. 138/2024;

c) garantire la riservatezza, l'integrità e la disponibilità dei dati del Committente per tutta la durata del Contratto e fino alla restituzione o cancellazione certa degli stessi;

d) conservare log di sicurezza accessibili al Committente per almeno 12 mesi, salvo obblighi normativi superiori.

1 Sicurezza della catena di fornitura e subfornitori

1.1 Il Fornitore è responsabile diretto della sicurezza dei propri Subfornitori che accedano ai dati o ai sistemi del Committente. È vietato l'affidamento a Subfornitori che non garantiscano standard di sicurezza equivalenti a quelli previsti dal presente Allegato, ai sensi di ISO 27001:2022 A.5.19, A.5.20, A.5.21 e dell'art. 21, par. 2, lett. d) NIS2.

1.1 Il Fornitore deve informare per iscritto il Committente di qualsiasi modifica sostanziale della catena di subfornitura ICT almeno 30 giorni prima dell'effettivo passaggio di consegne, salvo urgenze motivate per sicurezza.

1.1 Il Fornitore si impegna a inserire nei contratti con i propri Subfornitori clausole di sicurezza informatica almeno equivalenti a quelle previste nel presente Allegato, includendo obblighi di notifica, audit e risarcimento del danno.

2 Audit, ispezioni e test di sicurezza del Committente

2.1 Il Committente ha il diritto di svolgere Audit, ispezioni e test di sicurezza sui sistemi, le reti, i locali e la documentazione del Fornitore rilevanti per l'esecuzione del Contratto. Tali attività saranno condotte nel rispetto del segreto industriale e con preavviso di almeno 5 giorni lavorativi, salvo situazioni di emergenza cyber o richieste dell'ACN.

2.2 Il Fornitore è tenuto a correggere tempestivamente i gap riscontrati, fornendo un piano di remediation entro 10 giorni lavorativi dalla comunicazione scritta dei risultati e completando le azioni entro 30 giorni o secondo tempistiche concordate in funzione della criticità (ISO 27001:2022 – A.5.22 e Clausola 9.1).

2.3 Il Fornitore si obbliga a consentire Audit annuali programmati e Audit straordinari in caso di Incidente ICT o cambiamento significativo del profilo di rischio, con accesso ai report di revisione critica interna del Fornitore.

3 Notifica degli incidenti ICT

3.1 In caso di Incidente ICT che impatti o possa impattare il Committente, i servizi oggetto del Contratto o la supply chain, il Fornitore è obbligato a dare notifica immediata al Committente, entro e non oltre 24 ore dall'accertamento dell'evento, ai sensi dell'art. 23 NIS2 e dell'art. 23, co. 1, D.Lgs. 138/2024 Clausole fornitori.docx.

3.2 La notifica iniziale dovrà essere seguita da:

- un rapporto intermedio entro 72 ore;
- un rapporto finale entro un mese dall'evento, o secondo le tempistiche imposte dall'ACN o dal CSIRT competente.

3.3 Qualora l'incidente comporti una violazione di dati personali, il Fornitore notifica altresì l'evento ai sensi degli artt. 33-34 GDPR, coordinandosi con il Committente quale Titolare o Responsabile del trattamento.

3.4 Il Fornitore collabora attivamente alla valutazione dell'impatto, al contenimento, all'eradicazione e al ripristino, fornendo tutte le informazioni utili richieste dal Committente o dalle Autorità competenti.

4 Gestione delle vulnerabilità e patch management

4.1 Il Fornitore garantisce il mantenimento di un processo strutturato di gestione delle vulnerabilità (VM) e di *patch management* su tutti i sistemi, applicazioni e componenti di rete rilevanti per il Contratto (ISO 27001:2022 – A.8.7 e A.8.8).

4.2 Le patch di sicurezza devono essere applicate secondo le seguenti priorità, salvo diversa indicazione del Committente:

- **Critiche / Zero-day:** entro 7 giorni lavorativi dall'emissione o dalla pubblicazione del bollettino;
- **Alte:** entro 15 giorni lavorativi;
- **Medie/Basse:** entro 60 giorni lavorativi o secondo il piano di remediation concordato.

4.3 Il Fornitore si impegna a produrre, per le forniture software, un *Software Bill of Materials* (SBOM) aggiornato, al fine di garantire la tracciabilità delle componenti di terze parti e la gestione delle relative vulnerabilità.

5 Sviluppo sicuro e gestione del ciclo di vita

5.1 Per le forniture di software, firmware o sistemi tecnologici sviluppati o personalizzati, il Fornitore adotta un *Secure Development Life Cycle* (SDLC) conforme agli standard di settore e agli artt. 21 e 24 D.Lgs. 138/2024, che includa almeno:

- *threat modelling* in fase di progettazione;
- *code review* sicuro e rimozione di credenziali hardcoded;
- test di sicurezza automatici (SAST/DAST) e manuali;
- gestione sicura delle librerie di terze parti e verifica delle licenze.

5.2 Gli aggiornamenti, le modifiche e le nuove release dovranno essere sottoposti a validazione di sicurezza prima del rilascio in ambiente di produzione del Committente (ISO 27001:2022 – A.8.25, A.8.26, A.8.28).

6 Formazione e sensibilizzazione

6.1 Il Fornitore garantisce che il personale assegnato ai servizi del Committente riceva formazione e sensibilizzazione sulla sicurezza delle informazioni con periodicità almeno annuale, aggiornata in funzione dell'evoluzione delle minacce e del contesto normativo.

6.2 Il personale dovrà essere istruito sulle procedure da adottare in caso di Incidente ICT, sulle policy di gestione delle credenziali e sulle regole di accesso ai dati del Committente (ISO 27001:2022 – A.6.3, A.6.4).

7 Aggiornamento e miglioramento continuo

7.1 Il Fornitore si impegna ad adottare nuove misure, best practice e tecnologie non appena disponibili, come indicate da ENISA, ACN o standard ISO/IEC 27001:2022, e a fornire evidenza annuale degli aggiornamenti implementati.

7.2 Il Fornitore dichiara di mantenere un ciclo di miglioramento continuo conforme alla Clausola 10 della ISO/IEC 27001:2022 (*Plan-Do-Check-Act*), documentando revisioni della valutazione del rischio e azioni correttive.

8 Cooperazione e information sharing

8.1 In caso di Incidente o attività di intelligence sulle minacce rilevanti per il Committente, il Fornitore coopera con il Committente, con l'ACN e con il CSIRT competente, ai sensi degli artt. 23 e 25 NIS2 e degli artt. 23 e 25 D.Lgs. 138/2024.

8.2 Il Fornitore si impegna a partecipare, su richiesta del Committente, a esercitazioni periodiche di *tabletop* o *drill* per la verifica della capacità di risposta agli incidenti.

9 Documentazione e reportistica

Il Fornitore si obbliga a conservare e a rendere disponibile al Committente, entro i termini richiesti, la seguente documentazione:

a) rapporti di audit interno/esterno e certificazione ISO 27001 (se detenuta);

b) esiti di *Vulnerability Assessment* e *Penetration Test* (non oltre 12 mesi);

c) log di sicurezza e report di accesso ai sistemi del Committente;

d) piano di remediation e stato di avanzamento delle azioni correttive

10 Inadempimento, sanzioni e risoluzione

10.1 Il mancato, tardivo o inesatto adempimento anche di una sola delle clausole del presente Allegato costituisce inadempimento contrattuale rilevante. Si applica quanto previsto contrattualmente per l'apertura dei *ticket* e per il calcolo e l'applicazione delle penali.

10.2 In caso di violazione degli obblighi di sicurezza, il Committente ha dunque facoltà di:

a) irrogare penali di mora secondo quanto previsto dal Contratto;

b) richiedere la sostituzione del personale del Fornitore non conforme;

c) sospendere l'esecuzione del Contratto fino alla risoluzione dei gap;

d) procedere alla risoluzione del Contratto per inadempimento grave, ai sensi dell'art. 1456 c.c., e alla decadenza dai benefici contrattuali.

10.3 Resta salva l'applicazione delle sanzioni amministrative pecuniarie previste dall'art. 35 D.Lgs. 138/2024 per violazioni alla NIS2

11 Efficacia e sopravvivenza delle clausole

11.1 Il presente Allegato entra in vigore alla data di stipula del Contratto e resta efficace per tutta la durata dello stesso, inclusi eventuali periodi di proroga, rinnovo o transizione.

11.2 Le clausole di riservatezza, restituzione/cancellazione dei dati, notifica degli incidenti e responsabilità per danni da inadempimenti di sicurezza sopravvivono alla cessazione del Contratto per il periodo prescritto dalla legge o, in mancanza, per 5 anni.

12 Forza maggiore

Le obbligazioni di sicurezza informatica di cui al presente Allegato non possono essere considerate sospese per eventi di forza maggiore o *Act of God* se il Fornitore, attraverso l'adozione di misure di continuità operative e di disaster recovery adeguate (ISO 27001:2022 – A.5.24, A.5.30), avesse potuto prevenirne o mitigarne gli effetti.

2 DICHIARAZIONE DI RESPONSABILITA'

Il sottoscritto _____, in qualità di legale rappresentante / procuratore del Fornitore _____,

DICHIARA sotto la propria responsabilità:

1. che le informazioni riportate nella presente Checklist sono veritiere e corrispondenti allo stato effettivo;
2. di aver preso visione degli obblighi di cybersecurity previsti dall'Allegato Tecnico al Bando di Gara, compresi gli obblighi di notifica entro 24 ore, di audit, di aggiornamento *state-of-the-art* e di cooperazione in caso di incidente;
3. che il Fornitore si impegna a rispettare le clausole contrattuali che verranno inserite nel contratto finale ai sensi di NIS2 e D.Lgs. 138/2024.

Luogo, xx/xx/2026

Timbro e firma del Fornitore

_____